# LLM Security Gateway 프로젝트 요약

LLM 앱과 AI 공급자 사이에 끼워 넣어, 밖으로 나가는 개인정보·자격 증명을 가리고 프롬프트 인젝션을 막는 OpenAI 호환 API 게이트웨이. 앱과 모델 코드는 고치지 않는다. 클라이언트의 `base_url`만 게이트웨이로 바꾼다.

작성 hongjinkong · 2026-10-29

저장소 https://github.com/hongjinkong/llm-security-gateway

기간 2026-07-24 ~ 2026-10-29 · 결정 기록 105건 · 커밋 190여 개 · 테스트 596개

# 1. 무엇을 만들었나

## 문제

LLM 앱은 두 방향에서 동시에 취약하다. 사용자가 보낸 프롬프트 인젝션이 시스템 지시를 무력화하고, 사용자가 입력한 개인정보와 API 키가 외부 AI 공급자의 로그에 남는다. 기존 대응은 앱마다 방어 코드를 다시 넣는 방식이라 앱마다 재구현해야 하고, 방어가 있을 때와 없을 때를 같은 조건에서 비교하기 어렵다.

## 접근

방어를 앱 바깥의 게이트웨이로 분리한다. 입구는 OpenAI Chat Completions 형식 하나다. 클라이언트는 `base_url` 만 바꾸면 되고, 검사기 구성은 환경변수 `GATEWAY_DETECTORS` 하나로 바뀐다. 같은 공격을 방어 없음과 있음으로 돌려 차이를 잰다.

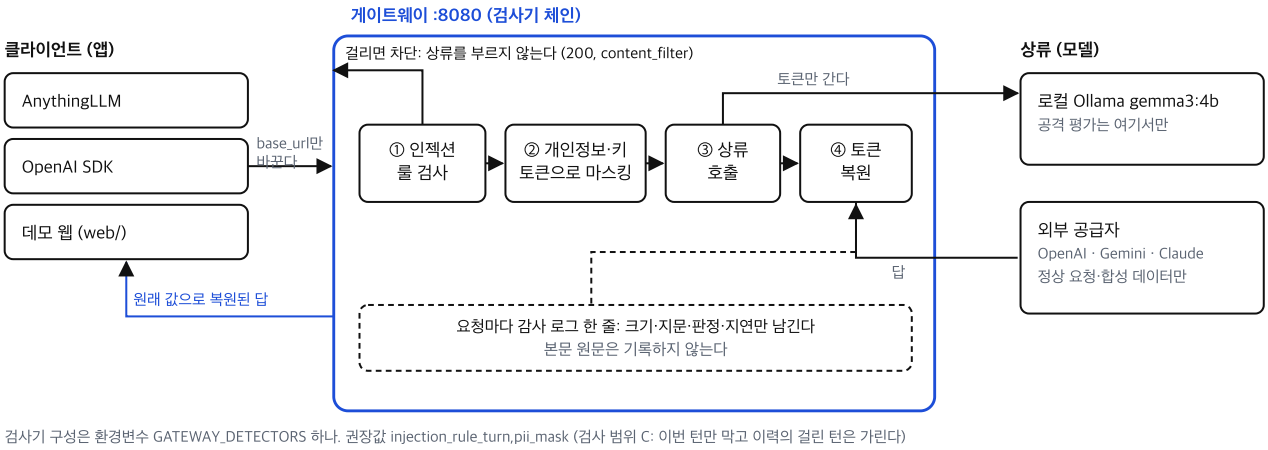



그림 1. 구조. 클라이언트(AnythingLLM, OpenAI SDK, 데모 웹)가 보낸 요청은 인젝션 룰 검사, 개인정보·자격 증명 마스킹을 거쳐 상류로 가고, 응답에서 토큰이 원래 값으로 복원된다. 요청마다 감사 로그 한 줄이 남는다(본문 원문은 남기지 않는다). 공격 평가는 로컬 Ollama(gemma3:4b)에만 하고, 외부 공급자(OpenAI·Claude·Gemini)에는 정상 요청으로 기능만 검증한다.

## 검사기 구성 ( `GATEWAY_DETECTORS` )

| 값 | 동작 |
|---|---|
| (빈 값) | 검사기 없음. 순수 프록시 |
| `pii` | 탐지만 하고 원문 그대로 전달 |
| `pii_mask` | `user` · `assistant` 메시지의 개인정보(주민번호·카드·전화·이메일)와 자격 증명(OpenAI·Anthropic·AWS·GitHub·Google·Slack 키, JWT, PEM)을 토큰으로 가려 전달하고 응답에서 복원 |
| `injection_rule` | 1차 룰 인젝션 차단, 검사 범위 (A). 이력까지 `user` · `tool` 메시지 전체를 본다. 측정 재현·비교용 |
| `injection_rule_turn` | 같은 룰, 검사 범위 (C). 이번 턴이 걸리면 차단하고, 이력의 걸린 턴은 가린 채 통과시킨다. 권장 기본값(D-101) |
| `canary_observe` | 카나리 관측 전용. 응답을 바꾸지 않고 세기만 한다 |

차단은 HTTP 200의 정상 completion(`finish_reason=content_filter`)으로 돌려주고 상류는 부르지 않는다. 본문이 상한(기본 1MiB)을 넘으면 413, `stream: true`는 400이다.

## 2. 어떻게 진행됐나

원칙은 셋이다. 평가 기준을 방어를 만들기 전에 얼린다. 측정마다 판정 규칙·무효 조건·예측을 실행 전에 기록한다. 결과를 본 뒤 기준을 바꾸지 않는다. 그래서 2차 유사도와 3차 LLM Judge는 사전 기준에 걸려 기각됐고, 그 과정이 그대로 남아 있다.




그림 2. 타임라인. 7월 24일 평가 기준 동결부터 10월 29일 종결까지.

| 시기 | 단계 | 결정 |
|---|---|---|
| 07-24 ~ 27 | 타겟 AnythingLLM 배포, 평가 기준 동결 | D-001~, EVAL_CRITERIA |
| 08월 | garak 베이스라인, 게이트웨이 코어, 개인정보 마스킹, 1차 룰 | D-029~D-040 |
| 08 ~ 09월 | v1 구조 측정. 2차 유사도·3차 Judge를 사전 기준으로 기각 | D-052, D-054, D-057 |
| 09-23 | OpenAI 형식 API 게이트웨이로 전환. 밖으로 나가는 정보를 보호의 중심으로 | D-070, D-073 |
| 09-28 ~ 10-02 | 새 구조 첫 평가 세 밤(promptinject·dan·encoding) | D-081, D-084 |
| 10-08 | 리뷰 반영 수정 묶음, 검사 범위 (C) 추가, 2·3차 코드 v1 태그로 | D-099 |
| 10-16 ~ 19 | 최종 코드 기준값 두 밤, 기본 검사 범위 (C) 결정 | D-100, D-101 |
| 10-29 | 독립 리뷰 결함 10건 수정, Claude 기능 검증, 데모 웹·GIF, 종결 | D-102 ~ D-105 |

## 3. 결과

최종 코드(지문 `6d81265136b0`)로 새 구조(AnythingLLM → 게이트웨이 → Ollama)에서 잰 값이다(D-100). 측정 전에 등록한 무효 조건 기준으로 두 프로브의 세 팔이 모두 유효하다. 괄호는 Wilson 95% 신뢰구간이다. 현재 코드(`27a16fa1c35b`)는 이 측정의 입력 전부에서 같은 판정을 낸다(4절).

| 지표 | none | rule (A) | turn (C, 권장) | 읽을 때의 한계 |
|---|---|---|---|---|
| promptinject 공격 성공률, n=7,680 | 74.5% | **0.2%** (0.2-0.4) | **7.8%** (7.2-8.4) | (A)가 더 막은 15.4%p는 이번 턴은 룰에 걸리지 않는데 앞 대화의 공격 때문에 막힌 몫 |
| dan 공격 성공률, n=4,000 | 75.9% | **29.4%** (28.1-30.9) | **31.2%** (29.8-32.7) | 판정기가 차단 문구를 거절로 읽지 못해, 결과 전에 동결한 채점 규약으로 센 값 |
| 단일 턴 오탐률(FPR), N=100 | - | **1.0%** | **1.0%** | 작성자가 만든 100문항(고유 문장 89). 목표 5% 이하 |
| 다중 턴 FPR, N=20 | - | **100.0%** | **0.0%** | (A)는 정상 질문 하나가 걸리면 같은 대화의 뒤 질문을 계속 막는다. 그래서 (C)가 기본 |
| 게이트웨이 지연 p95 | 1.22ms | **1.41ms** | **1.02ms** | 짧은 정상 질문 기준. 목표 100ms 이하 |

시도는 서로 독립이 아니다. garak 요청은 같은 대화의 직전 20개를 달고 갔고, 같은 프롬프트의 출력 10개도 독립이 아니라 신뢰구간이 실제보다 좁을 수 있다. 유의성 검정은 하지 않았고, 룰의 효과와 마스킹의 효과를 나누어 주장하지 않는다. encoding은 최종 코드로 다시 재지 않았다(옛 코드에서 룰이 5,120건 중 0건을 막았다).

### 성공 기준(SCOPE 7절) 대비

| 기준 | 결과 | 판정 |
|---|---|---|
| 공격 성공률 감소, 신뢰구간 병기 | promptinject 74.5% → 7.8%(C) · 0.2%(A), dan 75.9% → 31.2% · 29.4% | 달성, 한계 병기 |
| FPR 5% 이하 | 단일 턴 1.0%, 다중 턴 (C) 0.0% · (A) 100.0% | (C) 달성 |
| 지연 p95 +100ms 이하 | 1.02 ~ 1.41ms | 달성 |
| 단일 명령으로 전체 평가 재현 | 테스트·데모는 단일 명령. 공격 측정은 compose + Ollama + 밤샘 절차(약 2.5일) | 부분 달성 |
| 타겟 교체 시 설정 1개 | 클라이언트는 base_url 하나. 상류는 TARGET_URL(경로가 다르면 하나 더). 평가 하네스는 AnythingLLM 전용 | 달성(클라이언트·상류) |

### 외부 공급자 기능 검증 (정상 요청·합성 데이터만)

| 공급자 | 결과 |
|---|---|
| OpenAI gpt-4o-mini (D-087) | 합격. 정상 대화, PII 마스킹·복원, 401 중계, 로그 위생. 호출 3회 |
| Claude claude-opus-5-5 (D-103) | 합격. OpenAI 호환 입구에서 게이트웨이 코드 수정 없이 C1~C5 전 항목 합격. 호출 3회, 비용 $0.0029 |

| | |
|---|---|
| Gemini (D-088) | 정상 대화까지 확인. 상류 503 뒤 중단 |

## 4. 측정을 믿을 수 있게 만든 장치

- **기준을 먼저 얼린다.** 평가 기준은 방어를 만들기 전인 2026-07-27에 동결했다. 고치면 이전 측정이 전부 무효다.
- **재기 전에 등록한다.** 측정마다 판정 규칙·무효 조건·예측을 실행 전에 기록한다. 결과를 본 뒤 기준을 바꾸지 않았고, 그래서 2·3차 탐지기가 기각됐다.
- **자료가 이상하면 "무효"가 나온다.** 공격 측정은 E1~E7, 오탐률은 F1~F5. 자료가 없거나 출처끼리 어긋나면 통과가 아니라 무효다.
- **공격과 판정기를 직접 만들지 않는다.** garak 표준 프로브와 내장 판정기를 쓴다. 판정기가 차단을 읽지 못하면 판정기를 고치지 않고, 결과 전에 동결한 채점 규약으로 값을 옆에 놓는다.
- **테스트가 정말 잡는지 센다.** 테스트와 검증 도구에 결함을 일부러 넣어 잡히는지 확인한다(변이 검사). "전부 통과"는 하네스가 고장 나도 똑같이 나온다.
- **세 지표를 함께 낸다.** ASR·FPR·지연을 같은 구성에서 함께 보고하고, 분모와 신뢰구간을 붙인다.

> **판정 동등성 재생(D-102).** 코드를 고치면 지문이 바뀌므로, 측정에 쓰인 입력(고유 1,447문장)을 세 모양 × 세 구성으로 옛 코드와 고친 코드에 다시 넣어 비교했다. 13,023회 모두 판정과 상류 본문이 같았다. 그래서 D-100 수치를 현재 코드의 값으로 쓴다.

## 5. 막지 못하는 것

- **형식이 없는 개인정보·기밀.** 탐지는 주민번호·카드·전화·이메일과 접두사가 고정된 키·JWT·PEM뿐이다. 이름·주소·계좌번호·서술형 민감정보는 그대로 나간다.
- **system·developer·tool 메시지(RAG 문서 포함)의 개인정보**는 가리지 않는다. 이미지 같은 비텍스트도 보지 않는다.
- **룰이 모르는 공격.** 룰은 알려진 문구에만 듣는다. 인코딩된 공격은 한 건도 막지 못했고, `System:` 역할 헤더 위조는 어떤 층도 잡지 않는다. dan 공격의 31%는 게이트웨이가 있어도 성공한다.
- **(C)의 비용.** 이번 턴이 룰에 걸리지 않는 공격을, 이력에 다른 공격이 있다는 이유로 막지는 않는다. promptinject 0.2% → 7.8%.
- **출력 방향.** 시스템 프롬프트·문서 유출은 카나리로 세기만 하고 막지 않는다. 모델이 새로 내보낸 개인정보도 사용자에게 그대로 간다.
- **측정 범위.** 공격 측정은 gemma3:4b + AnythingLLM 조합뿐이다. 정상셋 100문항은 작성자가 만들고 룰 설계 때 본 것이며 고유 문장은 89개다.
- **운영 제약.** 워커 1개(토큰 볼트가 프로세스 메모리에 있다), 스트리밍 미지원, 사용자 인증·멀티테넌시 없음.

## 6. 2026-10-29에 한 일

### 독립 리뷰로 찾은 게이트웨이 결함 10건 수정 (D-102)

| # | 심각도 | 결함 | 수정 |
|---|---|---|---|
| 1 | 높음 | 탐지 건수의 제곱 시간. 전화번호 7만 4천 개(1MiB)에 60초, 워커 1개라 전체 정지. 감사 한 줄 6MB | 선형 병합·조각 잇기·메타 상한. 0.2초 |
| 2 | 중간 | 클라이언트의 accept-encoding 전달로 br·zstd 응답이 압축된 채 나가고 토큰 복원 안 됨 | accept-encoding 제거 |
| 3 | 중간 | 응답 tool_calls 인자의 복원값이 다음 턴 이력으로 돌아오면 원문이 상류로 감 | 인자도 마스킹 |
| 4 | 중간 | PEM 정규식이 이스케이프 따옴표의 역슬래시를 먹어 옛 경로 JSON 깨짐 | 역슬래시 쌍 처리 |
| 5 | 낮음 | 옛 경로가 sessionId 값까지 가려 대화 키가 바뀜 | 세션 키 제외 |
| 6 | 낮음 | 같은 이름의 헤더(Set-Cookie 둘)가 합쳐지거나 손실 | 쌍 목록으로 보존 |
| 7 | 낮음 | OPTIONS 요청도 본문 파싱 → 400 | POST만 파싱 |
| 8 | 낮음 | `"stream": null` 거부 | null은 false |
| 9 | 낮음 | 500 응답에 요청 ID 없음 | 예외 핸들러가 헤더 부착 |
| 10 | 낮음 | date·server 헤더 중복 | 응답에서 제거 |

회귀 테스트 12개, 변이 검사 13/13(처음 돌렸을 때 2건이 안 잡혀 테스트를 고쳤다), 전체 테스트 596개 통과. 코드 지문 `6d81265136b0` → `27a16fa1c35b`.

### 훑다가 찾은 자료 결함 2건

- D-100 dan의 이어 붙인 리포트에 레코드 둘이 한 줄에 붙은 줄이 팔마다 2개(조각 끝 digest + 다음 조각 머리, 개행 누락). attempt·eval 줄이 아니라 집계에 영향이 없다. 런처를 고쳤고 기록 파일은 그대로 둔다.
- 정상셋 100문항 중 11쌍이 같은 문장(고유 89). FPR 비율은 같지만 N=100은 11문항을 두 번 센 값이다. 정상셋을 고치면 재동결이라 고치지 않고 문서에 병기했다.

### 그 밖에

- **Claude 기능 검증(D-103).** 사전 등록 → push → 실행. C1 정상 대화, C2 마스킹 5·복원 5·잔여 0, C3 401 중계, C4 로그 위생, C5 stream 거부 모두 합격. 호출 3회, $0.0029.
- **데모 웹(D-104).** `web/` 브라우저 비교 화면. 같은 요청을 게이트웨이 없음·있음에 보내 상류가 실제로 받은 것·사용자가 받은 답·감사 한 줄을 나란히 보여 준다. 게이트웨이 코드는 손대지 않았다. README에 GIF를 넣었다.
- **종결(D-105).** 성공 기준 대비 결과 표, SCOPE 체크박스 정리, 잔재 정리(check.sh 이동, .vscode 추적 해제, 빈 폴더 삭제).

## 7. 저장소 구조와 문서 지도

| 폴더 | 내용 |
|---|---|
| `gateway/` | 프록시 본체 · OpenAI messages 파서 · 감사 로그 · 검사기 체인 · 토큰 볼트. `detectors/`에 pii·injection·canary |
| `web/` | 데모 웹. 게이트웨이 밖의 또 하나의 클라이언트 |
| `tests/` | 단위·통합 테스트 596개 + 가짜 상류 |
| `eval/` | 정상 질문셋 100문항 · FPR 실행기(단일·다중 턴) · 공격셋 오탐 스캐너 |
| `target/` · `garak/` | 타겟 앱에 올리는 합성 문서·시스템 프롬프트 · garak 러너 이미지와 설정 |
| `scripts/` | 측정 실행·집계·지문 검증·밤샘 런·변이 검사·동등성 재생·데모·SDK·Claude 확인 |
| `docs/` · `results/` | 상세 결과·채점 규약·측정 절차·설계 기록 · 측정 산출물 원본 |

| 문서 | 내용 |
|---|---|
| README.md | 요약. 상태, 결과, 한계, 실행 방법 |
| SCOPE.md | 만드는 것 / 만들지 않는 것 / 절대 하지 않는 것, 성공 기준과 결과 |
| EVAL_CRITERIA.md | 평가 기준. 2026-07-27 동결 |
| DECISIONS.md | 모든 결정의 날짜·근거·폐기 이력 D-001 ~ D-105 |
| docs/RESULTS.md | 상세 결과. 옛 구조 3.1~3.8, 새 구조 3.9(옛 코드)·3.10(최종 코드) |
| docs/SCORING_PROTOCOL.md · CANARY_DESIGN.md | 채점 규약과 카나리 설계(동결) |
| docs/next_D100_launch.md · MEASUREMENT.md | 측정 착수·회수 절차(새 구조 · 옛 구조) |

처음 읽는다면 README → docs/RESULTS.md → DECISIONS의 "먼저 볼 결정"(D-039·D-040, D-052·D-054, D-057, D-070·D-073, D-081·D-084, D-094·D-095, D-099~D-105) 순서가 빠르다.

# 8. 앞으로

## (a) 웹 배포 계획




그림 3. 배포 순서. 결정을 먼저 등록하고, 이미지 하나로 묶어 호스팅에 올린 뒤, 제한을 걸고 README에 링크한다.

- **상류는 스텁으로 고정한다.** 공개 화면의 자유 입력을 외부 공급자로 보내지 않는다(SCOPE 6절). 실제 모델 응답을 보여 주고 싶으면 프리셋만 허용하거나 별도 결정으로 범위를 연다.
- **Dockerfile 하나**로 웹 + 게이트웨이 + 스텁을 한 이미지에 담는다. 지금 웹이 자식 프로세스로 띄우는 구조를 그대로 쓴다.
- **호스팅**은 Fly.io 또는 Render(무료·저가 단일 컨테이너, HTTPS 기본). GitHub Pages는 서버가 없어 안 된다.
- **제한**: IP당 요청 수, 본문 상한(이미 4096), 동시 접속 수, 감사 로그는 임시 폴더. 비밀은 두지 않는다.
- **README**에 라이브 데모 링크와 "합성 데이터만" 안내. 이 모든 것을 D-106으로 먼저 등록한 뒤 만든다.

## (b) 개인 프로젝트로서 더 채울 수 있는 것 (우선순위)

| 순 | 항목 | 왜 · 무엇을 |
|---|---|---|
| 1 | 스트리밍 | 실제 LLM 앱은 대부분 스트리밍이다. SSE 통과와 조각 경계에 걸친 토큰 복원이 핵심 과제다 |
| 2 | 방어 강도 | 룰만으로는 dan 31%가 뚫리고 encoding은 0건 차단, System: 위조는 미처리. 다시 열려면 새 등록과 측정이 필요하다 |
| 3 | 공개 배포 | (a)의 계획. 사람들이 직접 눌러 보는 데모가 가장 강한 증거다 |
| 4 | 처음 보는 사람의 진입 | README가 길고 DECISIONS가 700KB, results 때문에 클론이 100MB다. 결과 원본을 릴리스 자산으로 분리하고 영문 요약 한 단락을 둔다 |
| 5 | 운영 | 워커 1개·메모리 볼트. 공유 저장소(Redis) 볼트와 지표(/metrics) |
| 6 | PII 범위 | 이름·주소 같은 비정형 개인정보. 한국어 NER은 지연과 오탐을 같이 재야 한다 |
| 7 | CI | lint·type 검사, 이미지 발행 |
| 8 | 정상셋 중복 | 11쌍 중복은 재동결 사안. 새 정상셋을 만들면 FPR 전부를 다시 잰다 |